WHAT ARE TRUST SIGNALS?

At ACME, every authorization decision relies on more than just identity. A customer's request to view a document or an engineer's attempt to deploy code also provides signals that indicate the trustworthiness of that request. These trust signals give policies the context they need to decide whether an action should be permitted.

Some signals describe who is acting—such as identity, employment status, or on-call role. Others show what they're using or how they're behaving. Together, these form a confidence profile for each request.

These are some common examples:

- **Device posture**—reported by an endpoint client or mobile device manager; indicates whether the laptop is encrypted, patched, or compliant.
- **Risk score**—generated by a fraud or threat detection service that evaluates behavior or login patterns.
- **Geolocation and network context**—based on IP, GPS, or VPN data—to flag unusual access.
- **Session assurance**—indications from authentication systems showing whether MFA was used or when a session was last validated.
- **Operational status**—feeds from systems such as PagerDuty or change management tools that reflect incident or deployment conditions.

These signals originate from multiple sources. As we'll see later in this chapter, some travel with the access token—like device-posture attestations—while others come through APIs or event streams. The Policy Information Point (PIP) collects, verifies, and normalizes them so policies are evaluated against trustworthy, current context.